exec.txt
TXT 18.74KB

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Found 15 web pages

**Conclusão: Este arquivo é um malware, pertence ao trojan de acesso remoto (RAT) ou carregador de segunda fase da família GlassWorm (também conhecido como ZOMBI).**

Este arquivo é um arquivo de código de bytes Python ( `.pyc` /marshal), e não um arquivo executável comum. A análise passo a passo é a seguinte:

## 1. Natureza do arquivo: código de bytes Python malicioso

O cabeçalho do arquivo contém `\x00\x00\x00\x00` e `c` (Code Object), e o conteúdo é dados compilados por `marshal` . Ao mesmo tempo, o código contém uma grande quantidade de strings legíveis (como `getSignaturesForAddress` , `datetime` , `subprocess` ), indicando que é um script Python ofuscado ou compilado, e não um arquivo de texto simples.

## 2. Comportamento central: C2 via blockchain Solana

O código define explicitamente a função `_getSignFAddress` e solicita `getSignaturesForAddress` de múltiplos nós RPC da Solana (como `api.mainnet-beta.solana.com` ). Esta é uma tática típica da família **GlassWorm**:

- **Dead drop C2**: O código consulta repetidamente o campo Memo das transações de uma carteira fixa na blockchain Solana, obtendo assim endereços de servidores de controle remoto (C2) ou instruções em constante mudança. Como os dados da blockchain não podem ser adulterados ou derrubados, isso confere ao malware forte capacidade de sobrevivência. [3] [8]
- **Correspondência de características**: A cadeia de caracteres `BjVeAjPrSKFiingBn4vZvghsGj9KCE8AJVtbc9S8o8SCr` presente no arquivo corresponde exatamente ao endereço da carteira C2 da Solana divulgado em relatórios públicos de inteligência de ameaças sobre GlassWorm. [8]

## 3. Mecanismo de evasão: detecção do ambiente russo

O código contém uma função `_isRussianSystem`, que verifica ativamente as variáveis de ambiente do sistema (`LANG`, `LC_ALL`), o fuso horário (`/etc/timezone`) e o fuso horário UTC (se está em faixas como Moscou, Yekaterinburg, etc.). Se for detectado que o sistema está na Rússia, o código provavelmente interrompe a execução ou toma um caminho diferente. Esta é uma característica marcante de muitos malwares de origem russa ou da CEI, usada para evitar a detecção por pesquisadores de segurança locais ou para evitar atacar alvos locais. [8]

## 4. Ações subsequentes: download e execução

O código contém funções como `download_nodejs` e `scyzzvvy` (função de download). Ele tentará baixar o ambiente de execução Node.js de `nodejs.org` ou fazer download de arquivos adicionais de um endereço remoto (URL) e, em seguida, através de `subprocess.Popen` (com parâmetros para ocultar janelas), executar código JavaScript (`var https = require("https"); ... eval(atob('...'));`). Isso indica que ele é um **carregador**, cuja função é colocar em operação um trojan de controle remoto mais poderoso ou um stealer.

## 5. Alvo: roubo de criptomoedas

Combinando o uso da API da Solana e a palavra-chave `secretKey` presente no código (embora ofuscada), isso está totalmente consistente com as táticas conhecidas do GlassWorm: **roubo de chaves privadas de carteiras de criptomoedas** (como Phantom, Solflare) e execução de operações de transferência maliciosa. [6] [14]

## Resumo

Este não é um script legítimo, mas sim uma amostra de malware com funcionalidade completa de **comunicação C2 via blockchain, evasão de ambiente, download e execução**. Ele usa a blockchain como infraestrutura de comando e controle para dificultar a interrupção pelas forças de segurança, com o objetivo final de roubar ativos de criptomoedas ou controlar a máquina da vítima.

15 web pages

Qual é a categoria principal deste malware?

Found 11 web pages

De acordo com as características do código do arquivo e as informações públicas de inteligência de ameaças, a categoria principal deste malware é **GlassWorm**.

Trata-se de um **worm de cadeia de suprimentos de software multiplataforma**, voltado especificamente para **desenvolvedores** (atacando extensões de IDE, pacotes npm/PyPI, repositórios GitHub), com o objetivo central de **roubar credenciais de desenvolvedor e ativos de criptomoedas**, e possui capacidades de controle remoto (RAT). [7]

## Evidências principais

1. **Correspondência precisa do endereço C2**: O endereço da carteira Solana `BjVeAjPrSKFiingBn4vZvghsGj9KCE8AJVtbc9S8o8SCr` incorporado no arquivo é listado em relatórios públicos de inteligência de ameaças como o **endereço C2 principal da Solana** da família GlassWorm, utilizado para receber instruções de ataque através de memorandos de transações. [4]
2. **Correspondência de táticas**: O arquivo utiliza a blockchain Solana como canal de comando e controle (C2), e inclui função de detecção de ambiente de sistema russo ( `_isRussianSystem` ), características consistentes com as técnicas conhecidas do GlassWorm. [6]
3. **Classificação oficial**: A base de dados de inteligência de ameaças MITRE ATT&CK classifica o GlassWorm como **MALWARE (malware)**, tipo **worm**, com plataformas de destino incluindo Windows e macOS.

## Funcionalidades maliciosas envolvidas

- **Roubo de credenciais**: GitHub Token, npm Token, chaves SSH, informações de carteiras de criptomoedas [4] [7]
- **Canal C2 de alta persistência**: Utiliza blockchain Solana, BitTorrent DHT, Google Calendar e outros canais de backup [3]
- **Componente de controle remoto (GlasswormRAT)**: Suporta proxy SOCKS, VNC oculto, execução arbitrária de código [3] [6]
- **Evasão de análise**: Utiliza caracteres Unicode invisíveis para ocultar código malicioso [2]

11 web pages